Agente de Terceros para un Sistema de Gestión de Privacidad Multiagente basado en ISO/IEC 27701:2025: Revisión Asistida de Contratos de Encargo con Recuperación Aumentada

Dylan Antonio Zúñiga Huarca, Jeferson Joao Basurco Casani, Adrian Issac Mamani Quispe
Escuela Profesional de Ingeniería de Sistemas
Universidad Nacional de San Agustín de Arequipa, Arequipa, Perú

***Resumen*—Cuando una organización encarga a un tercero el tratamiento de datos personales, conserva la responsabilidad sobre esos datos, y el contrato de encargo (DPA) es la principal garantía con la que cuenta. Revisar esos contratos frente a la Ley N.º 29733, su Reglamento (D.S. 016-2024-JUS) y el artículo 28 del RGPD es una tarea manual, repetitiva y propensa a omisiones. Este artículo presenta el *Agente de Terceros*, uno de los ocho agentes de un Sistema de Gestión de Privacidad de la Información (PIMS) multiagente basado en ISO/IEC 27701:2025, responsable de los controles A.1.2.7, A.2.5.7 y A.2.5.8. El agente contrasta cada DPA con 13 cláusulas mínimas mediante recuperación aumentada por generación (RAG): un índice FAISS de 978 fragmentos normativos con *embeddings* locales (`nomic-embed-text`) y una única llamada a Gemini 2.5 Flash con salida estructurada. Además, verifica literalmente las citas del modelo, calcula un cumplimiento ponderado, evalúa el riesgo del proveedor con una matriz 4×4, controla vencimientos y subencargados, y somete toda decisión a aprobación humana. Expone sus herramientas por *Model Context Protocol* (MCP) y una interfaz Flask. Una consulta adicional con vocabulario de la norma peruana eleva la cobertura de fuentes peruanas relevantes de 0,154 a 0,692. Sobre tres contratos anotados y 3 corridas por contrato, el agente alcanza una exactitud por cláusula de 87,2 %, una exactitud binaria (cumple / no cumple) de 92,3 % y un error absoluto medio de 5,6 puntos porcentuales en el índice de cumplimiento.**

***Index Terms*—Encargado del tratamiento, contrato de encargo, ISO/IEC 27701, gestión de terceros, RAG, sistemas multiagente, Ley 29733, auditoría de sistemas.**

I. Introducción

Las organizaciones externalizan cada vez más tratamientos de datos personales: alojamiento en la nube, planillas, pasarelas de pago, envío de correos, laboratorios. En todos esos casos el proveedor actúa como *encargado del tratamiento*, y quien le encarga el servicio sigue respondiendo por los datos. La Ley N.º 29733 prohíbe al encargado usar los datos con un fin distinto al del contrato y le obliga a suprimirlos al concluir el servicio (art. 30) [1]. Su Reglamento, aprobado por D.S. N.º 016-2024-JUS, regula la tercerización tecnológica (arts. 28-30), el encargo y la subcontratación (arts. 31-33) y obliga al encargado a informar de inmediato los incidentes de seguridad (art. 36) [2]. En la Unión Europea, el artículo 28 del RGPD enumera el contenido mínimo del contrato de encargo [3], desarrollado por las Directrices 07/2020 del CEPD [4] y las cláusulas contractuales tipo de la Decisión (UE) 2021/915 [5].

La norma ISO/IEC 27701:2025 convierte el sistema de gestión de privacidad (PIMS) en un estándar independiente y organiza sus controles por rol: la tabla A.1 para responsables, la tabla A.2 para encargados y la tabla A.3 para los controles compartidos [6]. Entre ellos, A.1.2.7 exige contratos con los encargados y A.2.5.7 a A.2.5.9 regulan la divulgación, la contratación y el cambio de subencargados. La gestión de terceros es además un frente de riesgo reconocido en la cadena de suministro [7].

El equipo de este Trabajo de Investigación Formativa (TIF) diseña un PIMS multiagente con ocho agentes especializados (inventario, riesgos, controles y SoA, evidencias, derechos, incidentes, terceros y formación), coordinados por un orquestador a través de un bus MCP [8], [9]. Este artículo describe el **Agente de Terceros (DPAs)**. Sus contribuciones son:

- un catálogo de 13 cláusulas mínimas del contrato de encargo, cada una trazada a la LPDP, al RLPDP, al RGPD y a los controles de ISO/IEC 27701:2025;
- un revisor de DPAs basado en RAG con *embeddings* locales y FAISS, que verifica literalmente las citas que produce el modelo;
- un modelo de riesgo de proveedores determinista y explicable, más el control de vencimientos, de subencargados y de la aprobación humana (HITL);
- una evaluación de la recuperación y de la revisión sobre contratos anotados, con el código y los datos disponibles.

II. Marco normativo y trabajos relacionados

II-A. El encargado en el Perú y en la Unión Europea

La Tabla I resume las obligaciones que el agente verifica. La norma peruana es menos detallada que el RGPD sobre el contenido del contrato, pero es más precisa en dos aspectos: fija un plazo máximo de conservación de dos años tras el último encargo (RLPDP art. 31.2) y obliga a evidenciar la supresión (art. 30.4).

Tabla I
OBLIGACIONES DEL ENCARGADO VERIFICADAS POR EL AGENTE

Obligación	Perú (LPDP / RLPDP)	UE (RGPD)
Fin limitado al contrato	LPDP 30; RLPDP 29.2, 33	Art. 28.3.a, 28.10
Subencargados	Autorización previa; carga de la prueba del encargado (RLPDP 32)	Autorización previa y aviso de cambios (28.2, 28.4)
Seguridad	RLPDP 30.3	Art. 28.3.c, 32
Incidentes	Informe inmediato (RLPDP 36)	Sin dilación indebida (33.2)
Fin del servicio	Supresión evidenciada; hasta 2 años (RLPDP 30.4, 31.2)	Supresión o devolución (28.3.g)
Transferencias	LPDP 15; RLPDP 12-14	Arts. 44-46

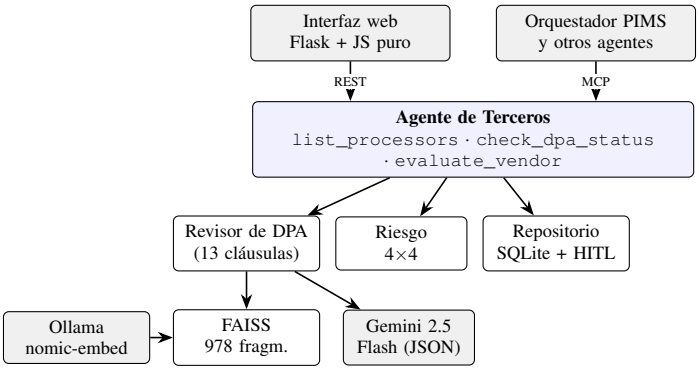


Figura 1. Arquitectura del Agente de Terceros dentro del PIMS multiagente.

II-B. ISO/IEC 27701:2025

La edición 2025 reestructura el Anexo A por roles [6]. El texto de la norma no es de libre acceso, así que el agente no lo indexa. En su lugar mantiene un catálogo de los títulos de los controles con una paráfrasis propia. La numeración de 2025 se infiere de la correspondencia con la edición de 2019 [10]: la tabla A.1 corresponde a la cláusula 7 y la tabla A.2 a la cláusula 8, con el último dígito desplazado en uno (por ejemplo, 7.2.6 $\rightarrow$ A.1.2.7 y 8.5.6 $\rightarrow$ A.2.5.7). Esta correspondencia debe confirmarse con el texto oficial.

II-C. Trabajos relacionados

La revisión automática de contratos cuenta con conjuntos de datos anotados por expertos como CUAD [11]. Sin embargo, los LLM aplicados al derecho producen afirmaciones no fundamentadas incluso en herramientas comerciales [12]. RAG mitiga ese riesgo al condicionar la generación a fragmentos recuperados [13], [14]. Para la búsqueda vectorial usamos FAISS [15] y, para los *embeddings*, el modelo abierto `nomic-embed-text` [16], que corre en local con Ollama. La aprobación humana sigue el enfoque *human-in-the-loop* [17], necesario cuando la decisión tiene efectos jurídicos.

III. ARQUITECTURA DEL AGENTE

La Fig. 1 muestra los componentes. El agente es un paquete de Python con una capa de servicio (`Agente`) que usan tanto la interfaz web (Flask con HTML, CSS y JavaScript puro) como el servidor MCP. Los datos operativos se guardan en SQLite con un esquema portable a PostgreSQL, que es la base de datos central del PIMS.

Las herramientas expuestas al bus MCP son las definidas para este agente en el diseño del PIMS:

- `list_processors`: lista los encargados con el estado de su DPA y su nivel de riesgo;
- `check_dpa_status`: indica si el DPA está vigente, por vencer (60 días), vencido, pendiente de aprobación o ausente;
- `evaluate_vendor`: devuelve la evaluación de riesgo con sus factores y recomendaciones;

Tabla II
CORPUS NORMATIVO DEL AGENTE

Sigla	Jurisdicción	Págs.	Fragm.
LPDP	Perú	17	64
RLPDP	Perú	60	175
RGPD	Unión Europea	87	455
EDPB-07/2020	Unión Europea	57	237
CCT-2021/915	Unión Europea	–	47
Total			978

CCT-2021/915 se obtuvo como texto HTML de EUR-Lex, sin paginación.

- `processors_in_breach`: apoya al Agente de Incidentes, que ante una brecha necesita saber qué encargados tratan la categoría de datos o el sistema afectado y si su contrato les obliga a notificar.

Puerta HITL. Todo DPA revisado y todo cambio de subencargado quedan *pendientes* hasta que Asesoría Legal o el DPO los aprueben o rechacen. Cada acción del agente y cada decisión humana se registra en una bitácora de auditoría (actor, acción, detalle y fecha), que sirve como evidencia para la cláusula 9 de la norma.

IV. METODOLOGÍA

IV-A. Corpus e indexación

El corpus (Tabla II) combina las normas peruanas, el RGPD y dos fuentes públicas especializadas en el encargo. El texto se extrae con `pypdf`, se limpia y se fragmenta en párrafos empaquetados hasta 1000 caracteres, con un solape de 150. Cada fragmento conserva su fuente, su jurisdicción, su página y el artículo o la cláusula detectados con expresiones regulares. Los vectores (768 dimensiones, con los prefijos de tarea de `nomic-embed-text`) se normalizan y se indexan en un `IndexFlatIP` de FAISS, que equivale a una búsqueda exacta por similitud coseno.

IV-B. Cláusulas mínimas

La Tabla III lista las 13 cláusulas. Cada una tiene un criterio de cumplimiento, su base normativa, los controles ISO que la sustentan, un peso $w \in \{1,2,3\}$ (recomendable, importante o esencial) y dos consultas de recuperación: una general y otra

Tabla III
CLÁUSULAS MÍNIMAS DEL CONTRATO DE ENCARGO

Cláusula	RGPD	ISO 27701	w
Objeto, duración, finalidad	28.3	A.1.2.7, A.2.2.3	3
Instrucciones documentadas	28.3.a, 29	A.2.2.3, A.2.2.5	3
Confidencialidad	28.3.b	A.2.2.2	2
Medidas de seguridad	28.3.c, 32	A.2.2.2, A.2.4.4	3
Subencargados	28.2, 28.4	A.2.5.7–A.2.5.9	3
Derechos de los titulares	28.3.e	A.2.3.2	2
Notificación de incidentes	28.3.f, 33.2	A.2.2.2, A.2.2.6	3
Supresión o devolución	28.3.g	A.2.4.3	3
Auditorías	28.3.h	A.2.2.6, A.2.2.7	2
Transferencias internacionales	44–46	A.2.5.2, A.2.5.3	2
Prohibición de fines propios	28.10	A.2.2.3	3
Solicitudes de autoridades	28.3.a	A.2.5.5	1
Asistencia en EIPD	28.3.f, 35	A.2.2.2	1

Tabla IV
RECUPERACIÓN POR CLÁUSULA (K = 6)

Estrategia	Hit@6	MRR	P@6	Cob. Perú
Solo consulta general	1,000	0,772	0,654	0,154
General + consulta peruana	0,923	0,733	0,538	0,692

Tabla V
ÍNDICE DE CUMPLIMIENTO C (%) FRENTE A LA REFERENCIA

Contrato	Ref.	Media	Rango	Exactitud
Completo (NubeSegura)	100,0	96,8	93,5–98,4	89,7 %
Intermedio (PagoFácil)	59,7	54,8	54,8–54,8	92,3 %
Deficiente (MailRápido)	17,7	26,3	21,0–30,6	79,5 %

con el vocabulario de la LPDP y el RLPDP (por ejemplo, "titular del banco de datos" o "subcontratación").

IV-C. Revisión de un DPA

1. **Recuperación por cláusula.** Para cada cláusula se recuperan seis fragmentos con la consulta general y dos fragmentos peruanos con la consulta local. Los resultados se unen sin duplicados y se ordenan por similitud. La numeración de los fragmentos es global y se comparte entre las cláusulas.
2. **Generación.** Una sola llamada a Gemini 2.5 Flash [18] recibe las cláusulas, los fragmentos numerados y el texto del contrato (o, si este supera 30 000 caracteres, sus fragmentos más pertinentes). Devuelve un JSON con el estado, la cita literal, los fundamentos y la recomendación de cada cláusula. Una sola llamada reduce la latencia y el consumo frente a trece llamadas separadas.
3. **Validación.** Se descartan los identificadores desconocidos y los estados inválidos. Una cláusula que el modelo no evalúa cuenta como "falta".
4. **Verificación literal.** La cita se divide en frases (separadas por punto o por elipsis) y cada frase de 20 caracteres o más debe aparecer en el contrato normalizado. Si una cláusula marcada como "cumple" no supera esta verificación, baja a "parcial" y se señala para revisión manual.
5. **Puntaje.** Con $v(\text{cumple}) = 1$, $v(\text{parcial}) = 0{,}5$ y $v(\text{falta}) = 0$,
$$C = 100\,\frac{\sum_i w_i\, v(e_i)}{\sum_i w_i}. \tag{1}$$

IV-D. Riesgo del proveedor

Siguiendo la gestión del riesgo de la AEPD y la NTP-ISO 31000 [19], [20], el riesgo es $R = P \times I$ con $P, I \in \{1, \ldots, 4\}$. El impacto parte del volumen de titulares (bajo, medio o alto) y suma 1 si se tratan datos sensibles. La probabilidad parte de 1 y suma 1 por cada uno de estos factores: transferencia a un país sin nivel adecuado, uso de subencargados, DPA sin revisar o con $C < 70$ y ausencia de un DPA vigente. Los incidentes de los últimos doce meses suman 1, o 2 si son tres o más. La certificación ISO/IEC 27701 resta 1. El nivel es bajo si $R \leq 3$, medio si $R \leq 6$, alto si $R \leq 9$ y crítico en otro caso, con revisiones cada 24, 12, 6 y 3 meses respectivamente. Que el modelo sea determinista es deliberado: el auditor debe poder reproducir el puntaje.

V. EVALUACIÓN

V-A. Recuperación normativa

Para cada una de las 13 cláusulas anotamos el conjunto de pares (fuente, artículo) relevantes. En el caso de las Directrices 07/2020, que no tienen artículos, contamos como relevantes las páginas 34 a 48, que desarrollan el contrato de encargo. Medimos Hit@6, MRR y P@6, y además la *cobertura peruana*: la proporción de cláusulas que recuperan al menos un fragmento peruano relevante. Esta métrica importa porque la LPDP y el RLPDP son la norma aplicable al caso.

La Tabla IV muestra que la búsqueda general recupera casi solo fuentes europeas, mucho más extensas y redactadas con el vocabulario del RGPD. La consulta con vocabulario peruano corrige ese sesgo: la cobertura peruana pasa de 0,154 a 0,692. El costo es una ligera caída de Hit@6 (de 1,000 a 0,923), porque en la cláusula de solicitudes de autoridades los dos fragmentos peruanos empujan fuera de los seis primeros puestos a los dos fragmentos relevantes (RGPD art. 28 y CEPD). En la práctica, el agente envía al modelo la unión completa (hasta ocho fragmentos), no solo los seis primeros. La primera versión del agente colocaba los fragmentos peruanos al inicio de la lista sin importar su similitud: con ella, el MRR caía a 0,455 y la cobertura peruana solo llegaba a 0,308. Ordenar la unión por similitud y usar una consulta específica para la norma peruana resolvió ambos problemas. La latencia media de recuperación es de 64 ms por cláusula, que se reparte entre el *embedding* local de la consulta y la búsqueda en FAISS.

V-B. Revisión de contratos

Construimos tres contratos ficticios con distinto grado de cumplimiento: uno completo, que contempla las trece cláusulas; uno intermedio, de una pasarela de pagos con varias cláusulas parciales o ausentes; y uno deficiente, de un servicio de *mailing* que permite usos propios y subencargados sin aviso. Los autores anotaron el estado esperado de cada cláusula ($3 \times 13 = 39$ etiquetas). Cada contrato se revisó 3 veces para medir la variabilidad del LLM.

Tabla VI
MATRIZ DE CONFUSIÓN AGREGADA (FILAS: REFERENCIA; COLUMNAS: AGENTE)

	cumple	parcial	falta
cumple	47	7	0
parcial	2	18	1
falta	0	5	37

Tabla VII
EFECTO DE LA REGLA DE CITA LITERAL EN EL PROMPT

Métrica	v1	v2 (final)
Exactitud por cláusula	84,6 %	87,2 %
Exactitud cumple / no cumple	87,2 %	92,3 %
Estabilidad entre corridas	76,9 %	89,7 %
Error absoluto medio de C (pp)	8,1	5,6
Citas que superan la verificación	90,8 %	98,9 %

El agente obtiene una exactitud por cláusula de 87,2 % y una exactitud binaria (cumple frente a no cumple) de 92,3 %. El error absoluto medio del índice es de 5,6 puntos porcentuales (Tabla V). El 89,7 % de las cláusulas recibe el mismo estado en las 3 corridas, y el 98,9 % de las citas aportadas supera la verificación literal. La latencia media de una revisión completa es de 32,0 s. La Tabla VI muestra que todos los errores ocurren entre estados adyacentes: el agente nunca confunde "cumple" con "falta". Los errores son ambigüedades de grado, el mismo tipo de caso en que dos auditores humanos suelen discrepar. El sesgo depende del contrato. En el completo, el agente es conservador (algunas cláusulas que cumplen quedan como parciales). En el deficiente es algo indulgente: califica como parciales cláusulas ausentes en las que el contrato dice algo relacionado, como la ley aplicable de Delaware en lugar de una cláusula de transferencias. Por eso sobreestima el índice (26,3 frente a 17,7).

Iteración del prompt. En la primera versión, el prompt pedía "copiar la frase literal", pero el modelo a veces resumía o parafraseaba la cita. La verificación literal rechazaba entonces esas citas y degradaba cláusulas que sí se cumplían: en una corrida, 7 de las 13 citas del contrato completo no superaron la verificación y el índice cayó a 67,7 %. Por eso reforzamos la regla: copiar carácter por carácter una o más frases completas, sin resumir, separando con "…" los tramos que estén en lugares distintos. La Tabla VII compara ambas versiones sobre los mismos contratos. La verificación literal cumplió su función: impidió que paráfrasis no comprobables contaran como evidencia.

V-C. Demostración

La Fig. 2 muestra la ficha de un proveedor de riesgo crítico y el informe de revisión de su contrato. Cada cláusula incluye su estado, la cita del contrato, la recomendación y los fragmentos normativos que la fundamentan, con fuente, artículo y página.

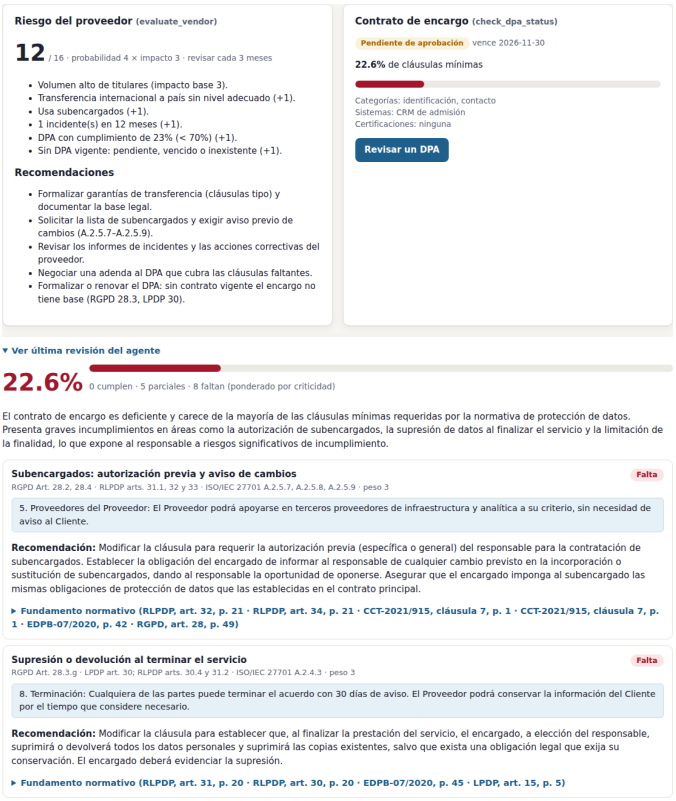


Figura 2. Interfaz del agente: riesgo del proveedor y estado del DPA (arriba); informe de revisión con citas y fundamentos (abajo).

VI. DISCUSIÓN Y LIMITACIONES

- **Conjunto de evaluación pequeño.** Tres contratos anotados por los propios autores bastan para detectar errores gruesos, pero no para generalizar. El siguiente paso es anotar contratos reales anonimizados con un abogado.
- **Variabilidad del LLM.** Aun con temperatura 0,1, el estado de algunas cláusulas cambia entre corridas. La verificación literal y la aprobación humana mitigan el riesgo, pero no lo eliminan.
- **Etiquetado de artículos.** Un fragmento hereda el primer encabezado que contiene, así que el final de un artículo puede aparecer etiquetado con el siguiente. Esto afecta tanto a las citas como a la anotación de relevancia.
- **ISO/IEC 27701:2025.** No se indexa su texto y la numeración de los controles es inferida.
- **Documentos escaneados.** Los PDF que solo contienen imágenes requieren OCR, que todavía no está implementado.

VII. CONCLUSIONES Y TRABAJO FUTURO

El Agente de Terceros automatiza la parte más repetitiva de la gestión de encargados: la lectura de contratos frente a las cláusulas exigibles. Además mantiene la trazabilidad normativa (fuente, artículo y página) y deja la decisión en manos humanas. Los *embeddings* locales con FAISS mantienen la recuperación dentro de la organización. Al LLM externo solo

se envían el contrato y los fragmentos públicos de la norma, nunca la base de datos personales, y una variante con un LLM local (Ollama) es directa. Como trabajo futuro planteamos: integrar el agente con el orquestador y con los agentes de Incidentes y de Controles a través del bus MCP; migrar el repositorio a la base PostgreSQL central del PIMS; generar adendas contractuales a partir de las cláusulas faltantes; y ampliar el conjunto de evaluación con contratos reales.

REFERENCIAS

[1] Congreso de la República del Perú, "Ley n.º 29733, ley de protección de datos personales," Diario Oficial El Peruano, 2011.

[2] Ministerio de Justicia y Derechos Humanos, "Decreto supremo n.º 016-2024-jus, reglamento de la ley n.º 29733, ley de protección de datos personales," Diario Oficial El Peruano, 30 nov., 2024.

[3] Parlamento Europeo y Consejo de la Unión Europea, "Reglamento (UE) 2016/679 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales (RGPD)," Diario Oficial de la Unión Europea, L 119, 2016.

[4] Comité Europeo de Protección de Datos, "Directrices 07/2020 sobre los conceptos de "responsable del tratamiento" y "encargado del tratamiento" en el RGPD, versión 2.0," CEPD, 2021.

[5] Comisión Europea, "Decisión de ejecución (UE) 2021/915 relativa a las cláusulas contractuales tipo entre responsables y encargados del tratamiento," Diario Oficial de la Unión Europea, L 199, 2021.

[6] ISO/IEC, "ISO/IEC 27701:2025 — information security, cybersecurity and privacy protection — privacy information management systems — requirements and guidance," International Organization for Standardization, 2025.

[7] J. Boyens, A. Smith, N. Bartol, K. Winkler, A. Holbrook, and M. Fallon, "Cybersecurity supply chain risk management practices for systems and organizations," National Institute of Standards and Technology, Tech. Rep. SP 800-161r1, 2022.

[8] Anthropic y colaboradores, "Model context protocol specification," https://modelcontextprotocol.io/specification, 2025.

[9] L. Wang, C. Ma, X. Feng, Z. Zhang, H. Yang, J. Zhang, Z. Chen, J. Tang, X. Chen, Y. Lin, W. X. Zhao, Z. Wei, and J.-R. Wen, "A survey on large language model based autonomous agents," 2024, vol. 18, no. 6, art. 186345.

[10] ISO/IEC, "ISO/IEC 27701:2019 — security techniques — extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — requirements and guidelines," International Organization for Standardization, 2019.

[11] D. Hendrycks, C. Burns, A. Chen, and S. Ball, "CUAD: An expert-annotated NLP dataset for legal contract review," 2021, arXiv:2103.06268.

[12] V. Magesh, F. Surani, M. Dahl, M. Suzgun, C. D. Manning, and D. E. Ho, "Hallucination-free? Assessing the reliability of leading AI legal research tools," 2024, arXiv:2405.20325.

[13] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems*, vol. 33, 2020, pp. 9459–9474.

[14] Y. Gao, Y. Xiong, X. Gao, K. Jia, J. Pan, Y. Bi, Y. Dai, J. Sun, M. Wang, and H. Wang, "Retrieval-augmented generation for large language models: A survey," 2023, arXiv:2312.10997.

[15] J. Johnson, M. Douze, and H. Jégou, "Billion-scale similarity search with GPUs," *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.

[16] Z. Nussbaum, J. X. Morris, B. Duderstadt, and A. Mulyar, "Nomic embed: Training a reproducible long context text embedder," 2024, arXiv:2402.01613.

[17] X. Wu, L. Xiao, Y. Sun, J. Zhang, T. Ma, and L. He, "A survey of human-in-the-loop for machine learning," *Future Generation Computer Systems*, vol. 135, pp. 364–381, 2022.

[18] Gemini Team, Google, "Gemini 2.5: Pushing the frontier with advanced reasoning, multimodality, long context, and next generation agentic capabilities," 2025, arXiv:2507.06261.

[19] Agencia Española de Protección de Datos, "Gestión del riesgo y evaluación de impacto en tratamientos de datos personales," AEPD, Madrid, 2021.

[20] INACAL, "NTP-ISO 31000:2018 gestión del riesgo. directrices," Instituto Nacional de Calidad, Lima, 2018.